

Cybersecurity Systems, Tools, and Standards: A Comprehensive Technical Briefing

Executive Summary

This briefing document provides a synthesized overview of core cybersecurity frameworks, network reconnaissance tools, protocol port standards, and data encoding methods. It serves as a technical reference for analysts to understand the structured methodologies used in defense, compliance, and incident analysis. Key takeaways include a taxonomy of international and industry-specific security frameworks, a detailed mapping of Nmap scanning parameters for network discovery, a compendium of standard network ports, and a reference for URL and data encoding used in secure communications and web application analysis.

1. Cybersecurity and Operational Frameworks

Cybersecurity frameworks are categorized by their specific utility, ranging from high-level governance and risk management to granular technical control implementations and threat modeling.

Core Security and Attack Frameworks

These frameworks provide the structural basis for organizational security posture and the analysis of adversary behavior.

Framework Name	Description / Usage	Key Indicators & Keywords
NIST SP 800-53	Security and privacy controls for federal information systems.	18 families of controls; Technical, Operational, and Managerial classes.
ISO/IEC 27001	Proprietary international standard for Information Security Management Systems (ISMS).	International standard; Requirements for ISMS.
Lockheed Martin Kill Chain	Outline of the stages involved in a network intrusion.	7 steps: Recon, Weaponization, Delivery, Exploitation, Installation, C2, Actions on Objectives.
MITRE ATT&CK	Knowledge base of adversary tactics, techniques, and procedures (TTPs).	Adversary behaviors; Knowledge base of tactics and techniques.
Diamond Model	Analyzes incidents by exploring relationships between four features.	Adversary, Capability, Infrastructure, and Victim; Meta-features.
NIST Cybersecurity Framework (CSF)	A risk-based framework focused on IT security over service provision.	Identify, Protect, Detect, Respond, and Recover; Core, Tiers, and Profiles.

Compliance and Industry-Specific Frameworks

These standards ensure adherence to regulatory requirements and best practices for specific data types or service environments.

- **PCI DSS:** Established by credit card companies to protect sensitive payment information; categorized into six main control objectives.
- **CIS Controls:** A set of best practice guidelines organized into Basic, Foundational, and Organizational categories, often referenced as the "Top 20 Critical Security Controls."
- **OWASP:** Focused specifically on web application security, most notably through the "Top Ten" list of vulnerabilities.
- **ITIL:** A framework dedicated to IT service delivery and management, emphasizing "Utility" (fit for purpose).
- **COBIT:** Used for IT governance, focusing on control selection, deployment, and regulatory compliance.
- **OSS TMM:** A framework for evaluating the quality and testing maturity of open-source software across five levels.

Specialized Technology Frameworks

- **SCAP (Security Content Automation Protocol):** A NIST framework for automating vulnerability scanning and ensuring SCAP-compliance.
- **Microsoft SDL:** A security framework specifically for application development supporting dynamic processes.
- **SASE (Secure Access Service Edge):** A cloud-based architecture combining network security with WAN capabilities, utilizing software-defined networking (SDN).
- **ESA (Enterprise Security Architecture):** A governance-based framework defining the baseline, goals, and methods for securing a business.

2. Network Reconnaissance: Nmap Command Reference

Nmap is a critical tool for host discovery, port scanning, and service fingerprinting. The following tables outline specific flags and their operational impacts.

Discovery and Stealth Parameters

These flags determine how Nmap identifies active hosts while attempting to manage visibility.

Flag	Description	Key Functional Context
-sn	Host Discovery Scan	Skips port scanning; identifies if hosts are active.
-sL	List Scan	Performs reverse-DNS queries to discover associated host names.
-PS	TCP SYN Ping	Uses a TCP SYN packet instead of ICMP to probe ports.
--scan-delay	Sparse Scanning	Adds significant delays between probes to avoid IDS/IPS detection.
-Tn	Scan Timing	Adjusts probe speed (0 is slowest/stealthiest, 5 is fastest).
-sI	TCP Idle Scan	Uses a "zombie" machine to hide the scanner's true identity.

-f	Fragmentation	Splits TCP headers across multiple IP datagrams to evade detection.
----	---------------	---

Port Scanning and Enumeration

These flags define the method of interaction with target ports to determine their state.

- **-sS (TCP SYN Scan):** Often called a "half-open" scan because it identifies port states without sending an ACK packet to complete the handshake.
- **-sT (TCP Connect Scan):** Completes the three-way handshake by sending an ACK packet.
- **-sN, -sF, -sX:** Specific scans that manipulate header bits (Null sets bits to zero; FIN sends an unexpected FIN packet; Xmas sets FIN, PSH, and URG flags to one).
- **-sU (UDP Scan):** Identifies the state of UDP ports based on responses or lack thereof (timeouts).
- **-p:** Allows targeting of specific port ranges rather than the default top 1,000.

Fingerprinting, Output, and Terminology

- **-sV:** Service detection to identify application names, versions, and protocols.
- **-A:** Intensive/Aggressive scan including OS detection and device type identification.
- **Output Formats:** Results can be saved as normal text (**-oN**), XML (**-oX**) for SIEM integration, or grepable (**-oG**) for easy searching.
- **Common Platform Enumeration (CPE):** A standard scheme for identifying hardware, OS, and applications.
- **Nmap Scripting Engine (NSE):** Utilizes Lua scripting for advanced vulnerability detection and probing.
- **Filtered State:** Indicates that a firewall is preventing Nmap from determining the port state.

3. Network Ports and Protocols

Understanding port assignments is essential for traffic analysis and firewall configuration. The Internet Assigned Numbers Authority (IANA) categorizes ports into three ranges: **Well-known** (0-1023), **Registered** (1024-49151), and **Dynamic/Private** (49152-65535).

Common Port Assignments

Port	Protocol	Service	Context/Description
21	TCP	FTP	File Transfer Protocol
22	TCP	SSH/SFTP	Secure Shell or FTP over SSH
23	TCP	TELNET	Unsecure remote administration
25	TCP	SMTP	Simple Mail Transfer Protocol
53	TCP/UDP	DNS	Domain Name System (TCP for zone transfers)
67/68	UDP	DHCP	Server (67) and Client (68) ports
80/443	TCP	HTTP/HTTPS	HyperText Transfer Protocol (Secure)
110/995	TCP	POP3(S)	Post Office Protocol (Secure)

135-139	Various	NetBIOS/RPC	Windows/UNIX RPC and legacy file sharing
143/993	TCP	IMAP(S)	Internet Mail Access Protocol (Secure)
161/162	UDP	SNMP	Simple Network Management Protocol (Agent/Trap)
445	TCP/UDP	SMB	Microsoft-DS (modern Windows file sharing)
500/4500	UDP	ISAKMP/NAT-T	IPsec tunnel setup and NAT traversal
514	UDP	Syslog	Server port for system logs
3306	TCP	MySQL	Database connection port
3389	TCP	RDP	Remote Desktop Protocol
8080	TCP	HTTP-Proxy	Alternative port for HTTP or proxy services

4. URL and Data Encoding Standards

Encoding ensures that data remains intact during transmission across different systems and protocols.

Percent (URL) Encoding

Percent encoding is used to represent 8-bit characters that have reserved meanings in URLs.

Character	Encoding	Character	Encoding
null	%00	.	%2E
space	%20	?	%3F
+	%2B	"	%22
%	%25	'	%27
/	%2F	<	%3C
\	%5C	>	%3E

Other Common Formats

- **Base64 Encoding:** Frequently used for encoding binary data (such as Windows portable executable headers) within email bodies using MIME. Notably, the ASCII "MZ" header appears as "TV" in Base64.
- **Unicode:** A format commonly extracted from executable files using tools like "Strings."
- **UTF-8/ASCII:** The standard character set allowed for unreserved characters (a-z, A-Z, 0-9) within URLs.